

MATERI KULIAH

Pertemuan 10: Manajemen Risiko Keamanan Data

Konsep Risiko • Risk Assessment • Risk Register • Vulnerability Assessment • Penetration Testing • Threat Modeling STRIDE

Mata Kuliah	Keamanan Data	Pertemuan	10 dari 16
Durasi	150 menit (3 SKS)	Metode	Ceramah, Workshop, Studi Kasus
Prasyarat	Pertemuan 1–9 (terutama CIA Triad & Keamanan Jaringan)	Tugas	Risk assessment sebuah sistem informasi

A. Capaian Pembelajaran Pertemuan

Setelah mengikuti pertemuan ini, mahasiswa diharapkan mampu:

- Menjelaskan konsep risiko dan komponennya (likelihood, impact, vulnerability, threat)
- Melakukan proses risk assessment secara sistematis menggunakan framework standar
- Menyusun risk register yang komprehensif untuk sistem informasi
- Membedakan pendekatan Vulnerability Assessment dan Penetration Testing
- Menerapkan metode threat modeling STRIDE untuk mengidentifikasi ancaman pada sistem
- Menentukan strategi mitigasi risiko yang tepat berdasarkan hasil analisis

B. Konsep Dasar Risiko Keamanan

1.1 Definisi & Komponen Risiko

Risiko (Risk) dalam konteks keamanan informasi adalah potensi kerugian atau kerusakan yang timbul ketika sebuah ancaman mengeksploitasi kerentanan pada suatu aset. Risiko bukan sekadar kemungkinan kejadian, tetapi juga dampak yang ditimbulkannya.

 Formula Risiko	$\text{RISIKO} = \text{Ancaman (Threat)} \times \text{Kerentanan (Vulnerability)} \times \text{Dampak (Impact)}$ Atau disederhanakan: $\text{RISIKO} = \text{Likelihood (kemungkinan terjadi)} \times \text{Impact (dampak jika terjadi)}$
---	--

Komponen	Definisi	Contoh
Aset (Asset)	Segala sesuatu yang bernilai bagi organisasi dan perlu dilindungi	Data pelanggan, server, aplikasi, reputasi, karyawan
Ancaman (Threat)	Potensi kejadian yang dapat merusak atau mencuri aset	Hacker, malware, bencana alam, human error, insider threat
Kerentanan (Vulnerability)	Kelemahan pada aset atau kontrol yang dapat dieksploitasi oleh ancaman	Software bug, password lemah, konfigurasi salah, patch belum update
Dampak (Impact)	Akibat negatif yang terjadi jika ancaman berhasil mengeksploitasi kerentanan	Kerugian finansial, bocornya data, reputasi rusak, sanksi regulasi
Likelihood	Probabilitas suatu ancaman berhasil mengeksploitasi kerentanan	Tinggi jika CVE sudah diketahui publik & belum di-patch

Kontrol (Control)	Langkah atau mekanisme untuk mengurangi risiko	Firewall, enkripsi, patch management, training karyawan
-------------------	--	---

1.2 Kategori Ancaman (Threat Categories)

Kategori	Deskripsi	Contoh Nyata
External Attacker	Penyerang dari luar organisasi yang mencoba meretas sistem	APT (Advanced Persistent Threat), ransomware gang, script kiddie
Insider Threat	Karyawan, kontraktor, atau mitra yang menyalahgunakan akses	Pegawai mencuri data pelanggan sebelum resign
Human Error	Kesalahan tidak disengaja oleh pengguna atau administrator	Admin salah konfigurasi firewall, user klik phishing email
Natural Disaster	Bencana alam yang mengganggu ketersediaan sistem	Banjir merusak data center, gempa bumi, kebakaran
System Failure	Kegagalan hardware atau software yang tidak disengaja	Hard drive crash, power outage, OS crash
Supply Chain Attack	Kompromi terjadi melalui vendor atau software pihak ketiga	SolarWinds attack, malicious npm package

C. Risk Assessment (Penilaian Risiko)

Risk Assessment adalah proses sistematis untuk mengidentifikasi, menganalisis, dan mengevaluasi risiko keamanan informasi. Proses ini menjadi dasar untuk memprioritaskan langkah-langkah mitigasi.

2.1 Proses Risk Assessment (5 Langkah)

No	Tahap	Aktivitas	Output
1	Asset Identification	Inventarisasi semua aset informasi: hardware, software, data, proses, SDM. Tentukan nilai/kritisitas setiap aset.	Daftar aset & valuasi
2	Threat Identification	Identifikasi semua ancaman yang relevan terhadap setiap aset. Gunakan threat library (MITRE ATT&CK, STRIDE).	Daftar ancaman per aset
3	Vulnerability Identification	Identifikasi kerentanan teknis maupun non-teknis. Gunakan VA tools, code review, audit manual.	Daftar kerentanan
4	Risk Analysis	Hitung kemungkinan (likelihood) dan dampak (impact) setiap risiko. Tentukan risk level menggunakan matriks risiko.	Risk score per ancaman
5	Risk Evaluation & Treatment	Bandingkan risk level dengan risk appetite. Tentukan tindakan: Accept, Avoid, Transfer, atau Mitigate.	Risk register & treatment plan

2.2 Metode Analisis Risiko

a. Analisis Kualitatif

Menggunakan skala deskriptif (Rendah/Sedang/Tinggi/Sangat Tinggi) untuk menilai likelihood dan impact. Lebih cepat dan mudah, cocok untuk tahap awal atau organisasi kecil.

Matriks Risiko (Risk Matrix) 5×5:

Likelihood → Impact ↓	Sangat Rendah (1)	Rendah (2)	Sedang (3)	Tinggi (4)	Sangat Tinggi (5)
Sangat Tinggi (5)	5	10	15	20	25
Tinggi (4)	4	8	12	16	20
Sedang (3)	3	6	9	12	15
Rendah (2)	2	4	6	8	10
Sangat Rendah (1)	1	2	3	4	5

Skor	Level	Tindakan yang Diperlukan
15–25	KRITIS	Tindakan segera diperlukan. Eskalasi ke manajemen. Hentikan operasi jika perlu.
8–12	TINGGI	Mitigasi dalam waktu dekat (< 30 hari). Senior management awareness.
4–6	SEDANG	Rencanakan mitigasi dalam jangka menengah (30-90 hari).
1–3	RENDAH	Pantau secara berkala. Mitigasi jika ada sumber daya.

b. Analisis Kuantitatif

Menggunakan nilai numerik dan perhitungan finansial untuk menilai risiko. Lebih objektif dan berguna untuk pengambilan keputusan investasi keamanan.

 Rumus ALE	AV = Asset Value (nilai aset dalam Rupiah) EF = Exposure Factor (% kerusakan jika terjadi insiden, 0.0–1.0) ARO = Annual Rate of Occurrence (berapa kali terjadi per tahun) SLE = Single Loss Expectancy = AV × EF ALE = Annual Loss Expectancy = SLE × ARO Contoh: Server senilai Rp 500 jt, EF=0.4, ARO=0.5 → SLE=Rp200jt → ALE=Rp100jt/tahun
---	--

2.3 Strategi Perlakuan Risiko (Risk Treatment)

Strategi	Penjelasan	Kapan Digunakan
 Avoid (Hindari)	Menghilangkan risiko dengan menghentikan aktivitas yang menjadi sumber risiko	Risiko terlalu tinggi & tidak ada mitigasi yang efektif. Contoh: batalkan proyek berisiko tinggi
 Mitigate (Kurangi)	Menerapkan kontrol untuk mengurangi likelihood atau impact risiko ke level yang dapat diterima	Paling umum digunakan. Contoh: patch software, tambah firewall, enkripsi data
 Transfer (Alihkan)	Mengalihkan dampak finansial risiko kepada pihak ketiga	Risiko finansial besar. Contoh: asuransi siber (cyber insurance), outsourcing

 Accept (Terima)	Menerima risiko tanpa tindakan mitigasi tambahan karena biaya mitigasi > dampak risiko	Risiko rendah, biaya mitigasi tidak ekonomis. Harus didokumentasikan & disetujui manajemen
--	--	--

D. Risk Register

Risk Register adalah dokumen hidup (living document) yang mencatat semua risiko yang teridentifikasi beserta analisis, pemilik risiko, status mitigasi, dan tindakan yang telah/akan dilakukan. Risk Register merupakan output utama proses risk assessment.

3.1 Komponen Risk Register

- Risk ID: Identifikasi unik setiap risiko
- Deskripsi Risiko: Penjelasan ancaman dan kerentanan yang mendasari
- Aset Terdampak: Aset mana yang berisiko
- Likelihood (1–5): Kemungkinan risiko terjadi
- Impact (1–5): Besarnya dampak jika risiko terjadi
- Risk Score: Likelihood × Impact
- Risk Level: Kritis/Tinggi/Sedang/Rendah
- Pemilik Risiko (Risk Owner): PIC yang bertanggung jawab
- Kontrol Eksisting: Kontrol yang sudah ada
- Strategi Treatment: Avoid/Mitigate/Transfer/Accept
- Rencana Tindak Lanjut: Langkah mitigasi spesifik
- Target Penyelesaian: Tenggat waktu mitigasi
- Status: Open/In Progress/Closed/Accepted

3.2 Contoh Risk Register — Sistem Informasi Akademik

ID	Deskripsi Risiko	Aset	L	I	Score	Level	Treatment	PIC	Status
R-01	SQL Injection pada form login mahasiswa	DB Nilai	4	5	20	KRITIS	Mitigate: Input validation, WAF, prepared statement	Dev Team	In Progress
R-02	Password admin default tidak diganti	Server App	3	5	15	KRITIS	Mitigate: Mandatory password change, MFA	Sysadmin	Open
R-03	Backup data tidak dilakukan rutin	DB Akademik	3	4	12	TINGGI	Mitigate: Otomasi backup harian, uji restore bulanan	DBA	In Progress
R-04	Akses login tanpa rate limiting	Portal Akademik	3	3	9	TINGGI	Mitigate: Implementasi rate limiting & CAPTCHA	Dev Team	Open
R-05	SSL/TLS belum diaktifkan di sub-domain	Web Server	2	4	8	TINGGI	Mitigate: Aktifkan HTTPS semua domain, HSTS	Sysadmin	Closed

R-06	Tidak ada log audit akses data sensitif	DB Nilai	2	3	6	SEDANG	Mitigate: Aktifkan DB audit log, SIEM integration	DBA	In Progress
R-07	Penggunaan library JS kadaluarsa	Aplikasi Web	2	2	4	SEDANG	Mitigate: Update dependency, SCA scanning rutin	Dev Team	Open
R-08	Downtime server karena power tanpa UPS	Server	1	3	3	RENDAH	Accept: Dokumentasikan, rencanakan UPS next budget	IT Infra	Accepted

E. Vulnerability Assessment vs Penetration Testing

Vulnerability Assessment (VA) dan Penetration Testing (PT) sering disalahartikan sebagai hal yang sama. Keduanya merupakan teknik berbeda dalam mengidentifikasi kelemahan keamanan, dengan tujuan, kedalaman, dan output yang berbeda.

4.1 Perbandingan VA vs Penetration Testing

Aspek	Vulnerability Assessment (VA)	Penetration Testing (PT)
Tujuan	Mengidentifikasi dan mengkatalog kerentanan yang ada pada sistem secara komprehensif	Mensimulasikan serangan nyata untuk membuktikan exploitability kerentanan
Kedalaman	Luas tapi tidak dalam — scan semua sistem, tidak mengeksploitasi	Dalam tapi tidak selalu luas — fokus mengeksploitasi target tertentu
Pendekatan	Otomatis menggunakan scanner tools. Pasif — tidak melakukan eksploitasi	Manual + tools. Aktif — mencoba mengeksploitasi kerentanan secara nyata
Durasi	Relatif cepat: hitungan jam hingga beberapa hari	Lebih lama: hitungan hari hingga minggu tergantung scope
Biaya	Lebih terjangkau, bisa dilakukan internal	Lebih mahal, biasanya memerlukan ethical hacker berpengalaman
Output	Daftar kerentanan + severity rating (CVSS score)	Laporan eksploitasi + proof-of-concept + rekomendasi rinci
Frekuensi	Bulanan atau setelah perubahan besar pada sistem	Tahunan atau sebelum go-live sistem baru
Tools Umum	Nessus, OpenVAS, Qualys, Rapid7 Nexpose	Metasploit, Burp Suite, Cobalt Strike, Kali Linux

4.2 Tahapan Vulnerability Assessment

#	Fase	Aktivitas	Tools
---	------	-----------	-------

1	Planning & Scoping	Tentukan scope (IP range, aplikasi, sistem), tujuan, timeline, dan batasan. Dapatkan izin tertulis (Rules of Engagement).	—
2	Asset Discovery	Identifikasi semua host aktif, port terbuka, layanan yang berjalan di jaringan.	Nmap, Masscan
3	Vulnerability Scanning	Jalankan scanner otomatis untuk mendeteksi CVE, misconfig, patch yang missing.	Nessus, OpenVAS, Qualys
4	Analysis & Validation	Analisis hasil scan, eliminasi false positive, verifikasi manualnya. Prioritaskan berdasarkan CVSS score.	CVSS Calculator
5	Reporting	Dokumentasikan semua temuan: deskripsi, severity, evidence, rekomendasi remediasi per kerentanan.	Laporan VA
6	Remediation & Re-scan	Tim developer/sysadmin melakukan perbaikan. Lakukan re-scan untuk verifikasi patch berhasil.	Nessus, OpenVAS

4.3 Metodologi Penetration Testing

Fase-Fase Penetration Testing

#	Fase	Aktivitas	Output
1	Reconnaissance (Pengintaian)	Passive: OSINT (LinkedIn, Shodan, WHOIS). Active: port scanning, service enumeration.	Target profile, attack surface map
2	Scanning & Enumeration	Identifikasi layanan, versi, OS. Enumerasi user, share, DNS. Banner grabbing.	Service map, potential entry points
3	Exploitation	Eksplorasi kerentanan yang ditemukan. Gunakan Metasploit, eksploitasi manual, password spraying.	Proof-of-concept, initial access
4	Post-Exploitation	Privilege escalation, lateral movement, data exfiltration simulation, persistence.	Extent of compromise report
5	Reporting	Laporan lengkap: executive summary, technical findings, PoC, CVSS score, rekomendasi.	Pentest report

Jenis Penetration Testing Berdasarkan Pengetahuan

Jenis	Deskripsi	Kelebihan / Kekurangan
Black Box	Pentest tidak memiliki informasi apapun tentang sistem target. Mensimulasikan serangan external attacker.	Realistis seperti serangan nyata / Bisa memakan waktu lama, mungkin melewati area tersembunyi
White Box (Crystal Box)	Pentest diberikan akses penuh: kode sumber, dokumentasi, kredensial, arsitektur sistem.	Coverage sangat komprehensif, efisien / Kurang realistis, tidak mensimulasikan attacker sesungguhnya
Grey Box	Pentest diberikan informasi parsial (misalnya: akun user biasa, IP range). Mensimulasikan insider threat atau attacker dengan akses terbatas.	Keseimbangan antara realistis dan efisien / Paling umum digunakan di industri

F. Threat Modeling — Metode STRIDE

Threat Modeling adalah proses terstruktur untuk mengidentifikasi ancaman keamanan pada tahap desain sistem, sebelum sistem diimplementasikan. Tujuannya adalah menemukan dan menangani kerentanan sedini mungkin (shift-left security), ketika biaya perbaikannya masih sangat murah.



Lebih murah memperbaiki desain di atas kertas daripada memperbaiki kerentanan di sistem yang sudah berjalan di produksi. Threat modeling dilakukan saat fase desain, bukan setelah deployment.

5.1 Proses Threat Modeling

7. Dekomposisi Aplikasi: Buat Data Flow Diagram (DFD) yang menunjukkan aliran data, komponen sistem, trust boundaries, dan entry points
8. Identifikasi Ancaman: Gunakan framework STRIDE untuk setiap komponen dan aliran data dalam DFD
9. Analisis Ancaman: Tentukan severity setiap ancaman menggunakan DREAD atau CVSS scoring
10. Tentukan Mitigasi: Rancang kontrol keamanan spesifik untuk setiap ancaman yang teridentifikasi
11. Validasi: Review hasil threat model bersama tim security dan development

5.2 Framework STRIDE

STRIDE adalah akronim yang dikembangkan oleh Microsoft untuk mengkategorikan enam jenis ancaman pada sistem perangkat lunak. Setiap huruf mewakili satu kategori ancaman:

	Kategori	Deskripsi Ancaman	Properti yang Dilanggar	Contoh Serangan
S	Spoofing (Pemalsuan Identitas)	Penyerang berpura-pura menjadi entitas lain (user, server, atau sistem) yang sah	Authentication	Phishing, ARP spoofing, IP spoofing, session hijacking, fake login page
T	Tampering (Perusakan Data)	Modifikasi data tanpa otorisasi, baik data saat transit maupun yang tersimpan	Integrity	SQL injection, man-in-the-middle, file tampering, log manipulation
R	Repudiation (Penyangkalan)	Pengguna atau penyerang menyangkal telah melakukan aksi tertentu karena tidak ada bukti	Non-repudiation	Menghapus log, transaksi tanpa tanda tangan digital, aksi tanpa audit trail
I	Information Disclosure (Kebocoran Informasi)	Data sensitif terekspos kepada pihak yang tidak berwenang	Confidentiality	Data breach, directory traversal, verbose error messages, unencrypted storage
D	Denial of Service (Gangguan Layanan)	Penyerang membuat layanan tidak tersedia bagi pengguna yang sah	Availability	DDoS, SYN flood, resource exhaustion, ransomware, buffer overflow
E	Elevation of Privilege (Eskalasi Hak Akses)	Penyerang mendapatkan hak akses lebih tinggi dari yang seharusnya dimiliki	Authorization	Privilege escalation, sudo exploit, token manipulation, IDOR vulnerability

5.3 Mitigasi per Kategori STRIDE

Ancaman		Kontrol Mitigasi yang Direkomendasikan
S	Spoofing	Autentikasi kuat (MFA, OAuth 2.0, SAML), validasi sertifikat TLS, mutual authentication, anti-phishing training
T	Tampering	HMAC, digital signature, input validation & sanitization, enkripsi data at rest & in transit, file integrity monitoring
R	Repudiation	Audit logging komprehensif (siapa, apa, kapan, dari mana), digital signature pada transaksi kritis, tamper-proof log storage
I	Information Disclosure	Enkripsi end-to-end, least privilege, data classification & masking, error handling yang tidak mengekspos info sistem, DLP
D	Denial of Service	Rate limiting, CAPTCHA, CDN dengan DDoS protection, load balancer, auto-scaling, circuit breaker pattern, resource quota
E	Elevation of Privilege	Principle of least privilege, sandboxing, input validation, secure defaults, regular privilege review, PAM (Privileged Access Management)

5.4 Studi Kasus: Threat Modeling Sistem Login

Skenario: Aplikasi web e-commerce memiliki fitur login pengguna. Aktor: User, Browser, Web Server, Auth Service, Database. Berikut aplikasi STRIDE pada komponen tersebut:

STRIDE		Ancaman pada Sistem Login	Severity	Mitigasi
S	Spoofing	Penyerang membuat halaman login palsu (phishing) atau mencuri session token	Tinggi	HTTPS wajib, HSTS, session token dengan expiry pendek, logout otomatis
T	Tampering	Modifikasi password di database, manipulasi response autentikasi	Kritis	Hashing bcrypt, validasi server-side, tanda tangan JWT, HTTPS
R	Repudiation	Pengguna menyangkal telah melakukan login atau transaksi tertentu	Sedang	Log audit setiap login (IP, waktu, user-agent), tanda tangan digital transaksi
I	Information Disclosure	Error message mengekspos 'username tidak ditemukan' vs 'password salah'	Sedang	Generic error message: 'Username atau password salah'
D	Denial of Service	Brute force login menghabiskan resource server	Tinggi	Rate limiting, account lockout setelah 5 gagal, CAPTCHA, progressive delay
E	Elevation of Privilege	User biasa mengakses fitur admin melalui parameter manipulation	Kritis	Server-side authorization check, RBAC ketat, tidak bergantung pada client-side check

G. Framework Manajemen Risiko

Framework	Diterbitkan Oleh	Fokus Utama	Cocok Untuk
NIST RMF (SP 800-37)	NIST (AS)	Siklus manajemen risiko 6 tahap: Categorize → Select → Implement → Assess → Authorize → Monitor	Lembaga pemerintah AS, kontraktor pemerintah
ISO 31000	ISO/IEC	Framework manajemen risiko generik, berlaku untuk semua jenis risiko organisasi	Semua jenis organisasi, fleksibel
ISO 27005	ISO/IEC	Manajemen risiko khusus keamanan informasi, terintegrasi dengan ISO 27001	Organisasi yang menerapkan ISMS ISO 27001
FAIR (Factor Analysis of Information Risk)	Open Group	Kuantifikasi risiko dalam nilai finansial menggunakan model probabilistik	CISO, pengambilan keputusan investasi keamanan
OCTAVE	Carnegie Mellon	Risk assessment berbasis aset dengan pendekatan self-directed, fokus pada risiko operasional	Organisasi menengah, tidak memerlukan konsultan eksternal

H. Ringkasan Konsep Kunci

Konsep	Poin Utama
Formula Risiko	Risiko = Likelihood × Impact. Komponen: Aset, Ancaman, Kerentanan, Dampak, Kontrol
Risk Assessment	5 langkah: Identifikasi Aset → Ancaman → Kerentanan → Analisis → Treatment. Output: Risk Register
Risk Matrix	Skor 1–25. Kritis (15–25): tindakan segera. Tinggi (8–12): < 30 hari. Sedang (4–6): < 90 hari
Risk Treatment	4 strategi: Avoid (hindari), Mitigate (kurangi), Transfer (asuransi), Accept (terima & dokumentasikan)
Risk Register	Dokumen hidup berisi semua risiko + score + pemilik + treatment + status. Harus selalu diperbarui
VA vs Pentest	VA = scan luas & otomatis (tidak eksploitasi). Pentest = eksploitasi nyata, lebih dalam, lebih mahal
STRIDE	Spoofing-Tampering-Repudiation-Information Disclosure-DoS-Elevation of Privilege. Dilakukan saat desain sistem

I. Latihan & Tugas

Soal Diskusi (In-Class)

12. Sebuah perusahaan e-commerce memiliki kerentanan XSS pada kolom komentar produk. Vulnerability sudah diketahui selama 2 bulan tapi belum diperbaiki. Hitung ALE jika: nilai reputasi = Rp 2 miliar, EF = 0.3, probabilitas dieksploitasi = 60% per tahun.
13. Jelaskan perbedaan antara threat dan vulnerability dengan contoh konkret pada sistem perbankan. Mengapa penting membedakan keduanya dalam proses risk assessment?
14. Kapan sebuah organisasi sebaiknya memilih melakukan Vulnerability Assessment saja tanpa Penetration Testing? Berikan justifikasi.
15. Aplikasi mobile banking memiliki fitur transfer dana. Lakukan analisis STRIDE untuk fitur tersebut — identifikasi minimal satu ancaman per kategori STRIDE beserta mitigasinya.
16. Mengapa strategi 'Accept' dalam risk treatment harus tetap didokumentasikan dan disetujui manajemen? Apa risikonya jika tidak didokumentasikan?

Tugas Workshop (Kelompok 3–4 Orang)



Lakukan Risk Assessment untuk sistem perpustakaan digital kampus yang memiliki: portal web untuk peminjaman buku digital, database anggota & koleksi buku, sistem autentikasi SSO, dan akses via mobile app. Tugas meliputi: (1) Identifikasi minimal 8 aset kritis, (2) Identifikasi ancaman menggunakan STRIDE, (3) Buat Risk Register dengan minimal 10 entri risiko termasuk skor dan strategi treatment, (4) Rekomendasikan 3 kontrol prioritas tertinggi beserta justifikasinya. Format: dokumen Word + presentasi 10 menit di pertemuan berikutnya.

J. Referensi & Bacaan Lanjutan

- NIST SP 800-30 Rev.1: Guide for Conducting Risk Assessments — csrc.nist.gov
- NIST SP 800-37 Rev.2: Risk Management Framework for Information Systems — csrc.nist.gov
- ISO/IEC 27005:2022 — Information Security Risk Management
- Microsoft STRIDE Threat Modeling: learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool
- OWASP Threat Modeling Cheat Sheet — cheatsheetseries.owasp.org
- MITRE ATT&CK Framework — attack.mitre.org (Threat library lengkap)
- Shostack, A. (2014). Threat Modeling: Designing for Security. Wiley.
- The Open Group: FAIR Risk Taxonomy — opengroup.org